เอกสารประกอบการปฏิบัติการ
รายวิชา CP423324 Database and Web Security
Lab 9: Input Validation and Secure Error Handling

วัตถุประสงค์

1. เพื่อให้นักศึกษาสามารถตรวจสอบข้อมูลฝั่งเซิร์ฟเวอร์ (Server-side Validation) ก่อนนำข้อมูลไปประมวลผลหรือบันทึกลงฐานข้อมูลได้
2. เพื่อให้นักศึกษาสามารถตรวจสอบข้อมูลตามชนิด (Type) รูปแบบ (Format) ความยาว (Length) และค่าที่อนุญาต (Allowlist) ได้
3. เพื่อให้นักศึกษาสามารถแสดงข้อความผิดพลาดที่เหมาะสมแก่ผู้ใช้ โดยไม่เปิดเผย SQL Error, File Path หรือรายละเอียดภายในของระบบได้
4. เพื่อให้นักศึกษาสามารถบันทึกรายละเอียดข้อผิดพลาดไว้ใน Server Log ด้วย error_log() เพื่อใช้ตรวจสอบภายหลังได้

คำชี้แจง

1. ให้นักศึกษา Capture ผลลัพธ์ตามที่งานของแต่ละข้อกำหนดลงใน Word และบันทึกไฟล์เป็น PDF โดยให้ตั้งชื่อว่า Lab09_รหัสนักศึกษา(มีขีด).pdf
2. เมื่อทำเสร็จเรียบร้อยแล้วให้แจ้งผู้ช่วยสอน (TA) เพื่อขอรับการตรวจและตอบคำถาม (กรุณาตรวจกับพี่ TA โดยคะแนนจะมาจากการตรวจในห้องเรียน)
3. เมื่อตรวจกับ TA เรียบร้อยแล้วให้นักศึกษาส่งใน Classroom เพื่อเป็นการสำรองข้อมูล
4. ไม่อนุญาตให้ส่งงานย้อนหลังได้ ยกเว้นกรณีลาป่วย หรืออุบัติเหตุ (ต้องมีใบรับรองแพทย์)

★★★★★★★★★★

โจทย์ที่กำหนด

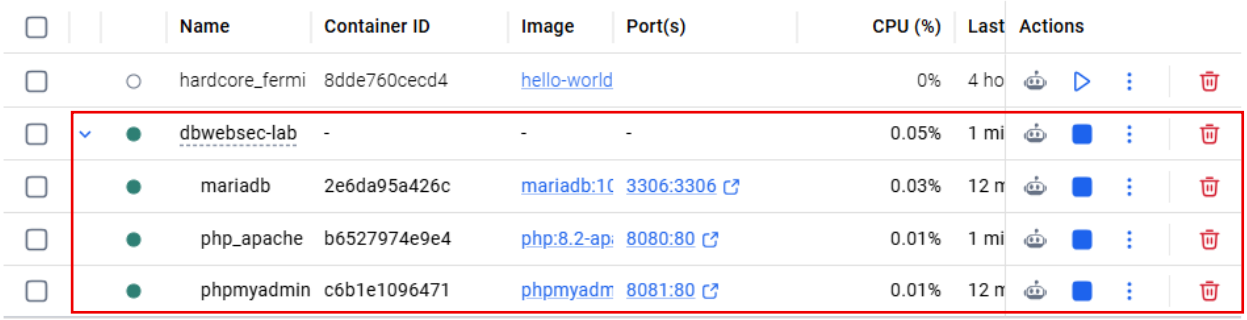
งานปฏิบัติการนี้ให้นักศึกษาพัฒนาเว็บแอปพลิเคชันต่อจากระบบค้นหาข้อมูลหนังสือ จากLab08 โดยเพิ่มหน้า เพิ่มข้อมูลหนังสือ (Add Book) และปรับปรุงระบบให้ตรวจสอบข้อมูลฝั่งเซิร์ฟเวอร์ รวมทั้งจัดการข้อผิดพลาดอย่างปลอดภัยก่อนบันทึกข้อมูลลงฐานข้อมูล

ลำดับการพัฒนาระบบ

1. เตรียมฐานข้อมูล db_lab08 และตาราง books
2. สร้างไฟล์ Lab09_add_book_insecure.php ตัวอย่างสำหรับทดลองผลเมื่อไม่มี Server-side Validation และแสดง Error ไม่ปลอดภัย
3. ทดสอบการกรอกข้อมูลปกติ, Bypass Client-side Validation และทดสอบ Insecure Error Handling
4. สร้างไฟล์ Lab09_add_book_secure.php ที่ใช้ Server-side Validation และ Prepared Statement ทำงานร่วมกับ Secure Error Handling

โดยมีขั้นตอนการพัฒนาระบบ ดังนี้

1. เปิด docker ที่เคยสร้างไว้ ให้ Start container name: dbwebsec-lab, mariadb, php_apache และ phpmyadmin



	Name	Container ID	Image	Port(s)	CPU (%)	Last	Actions
☐	hardcore_fermi	8dde760cecd4	hello-world		0%	4 ho	
☐	dbwebsec-lab	-	-	-	0.05%	1 mi	
☐	mariadb	2e6da95a426c	mariadb:1(	3306:3306	0.03%	12 n	
☐	php_apache	b6527974e9e4	php:8.2-ap:	8080:80	0.01%	1 mi	
☐	phpmyadmin	c6b1e1096471	phpmyadm	8081:80	0.01%	12 n	

2. การใช้ฐานข้อมูลและตารางที่สร้างไว้ใน Lab08 โดยมีฐานข้อมูลชื่อ db_lab08 และตาราง books โดยเพิ่ม Attribute ในตาราง books อีก 3 field เพื่อให้สามารถฝึก Validation ได้หลายรูปแบบ ได้แก่ isbn, publish_year และ stock ซึ่งมีรายละเอียด ดังนี้

Field	Data Type	ข้อกำหนด	Validation	เงื่อนไข	ตัวอย่าง Error
id	INT	PRIMARY KEY, AUTO_INCREMENT	-	-	-
title	VARCHAR(150)	Not Null	Required + Length	ไม่ว่าง, ≤ 150 ตัวอักษร	Title is required. / Title is too long.
author	VARCHAR(100)	Not Null	Required + Length	ไม่ว่าง, ≤ 100 ตัวอักษร	Author is required. / Author is too long.
category	VARCHAR(50)	Not Null	Allowlist	Database / Programming / Security	Invalid category.
price	DECIMAL(8,2)	Not Null	Type + Range	0.01 - 999999.99	Invalid price.
publish_year	INT		Type + Range	1900 ถึงปีปัจจุบัน	Invalid publish year.
isbn	VARCHAR(20)		Format	ISBN-10 / ISBN-13	Invalid ISBN format.
stock	INT		Type + Range	0 - 100000	Invalid stock.

ตัวอย่างคำสั่ง SQL

สร้างฐานข้อมูล db_lab08

```
CREATE DATABASE IF NOT EXISTS db_lab08
CHARACTER SET utf8mb4
COLLATE utf8mb4_unicode_ci;
```

สร้างตาราง

```
CREATE TABLE books (
    id INT AUTO_INCREMENT PRIMARY KEY,
    title VARCHAR(150) NOT NULL,
    author VARCHAR(100) NOT NULL,
    category VARCHAR(50) NOT NULL,
    price DECIMAL(8,2) NOT NULL
);
```

แก้ไขตาราง books โดยเพิ่ม Attribute ในตาราง books อีก 3 field

```
ALTER TABLE books
    ADD COLUMN IF NOT EXISTS isbn VARCHAR(20) NULL,
    ADD COLUMN IF NOT EXISTS publish_year INT NULL,
    ADD COLUMN IF NOT EXISTS stock INT NOT NULL DEFAULT 0;
```

แม้ Database จะอนุญาต NULL แต่ใน Web Application ของ Lab09 กำหนดให้ ISBN Publish Year และ stock เป็น Required

ผลลัพธ์จากการแก้ไข ตาราง books ต้องมี field isbn, publish_year และ stock เพิ่มขึ้น ดังนี้

#	Name	Type	Collation	Attributes	Null	Default	Comments	Extra
1	**id**	int(11)			No	*None*		AUTO_INCREMENT
2	**title**	varchar(150)	utf8mb4_unicode_ci		No	*None*		
3	**author**	varchar(100)	utf8mb4_unicode_ci		No	*None*		
4	**category**	varchar(50)	utf8mb4_unicode_ci		No	*None*		
5	**price**	decimal(8,2)			No	*None*		
6	**isbn**	varchar(20)	utf8mb4_unicode_ci		Yes	*NULL*		
7	**publish_year**	int(11)			Yes	*NULL*		
8	**stock**	int(11)			No	0		

3. การสร้างเว็บแอปพลิเคชัน

ให้นักศึกษาสร้างโฟลเดอร์ Lab09 ไว้ภายใน C:\dbwebsec-lab\www สำหรับไฟล์ที่ต้องสร้างมีไฟล์ทั้งหมด 3 ไฟล์ มีรายละเอียด ดังนี้

1) Lab09_config.php เชื่อมต่อฐานข้อมูลด้วย webapp_user
2) Lab09_add_book_insecure.php หน้าเพิ่มข้อมูลลงตาราง books ที่มีความผิดพลาด
3) Lab09_add_book_secure.php หน้าเพิ่มข้อมูลลงตาราง books ที่มีการป้องกันข้อผิดพลาด (นักศึกษาสร้างเอง)

3.1 การสร้างไฟล์ Lab09_config.php โดยมีคำสั่ง ดังนี้

```php
<?php
declare(strict_types=1);

date_default_timezone_set('Asia/Bangkok');

const DB_HOST = 'db';
const DB_PORT = 3306;
const DB_NAME = 'db_lab08';
const DB_USER = 'webapp_user';
const DB_PASS = 'WebApp1234';

mysqli_report(MYSQLI_REPORT_ERROR | MYSQLI_REPORT_STRICT);

try {
    $conn = new mysqli(
        DB_HOST,
        DB_USER,
        DB_PASS,
        DB_NAME,
        DB_PORT
    );

    $conn->set_charset('utf8mb4');
    $conn->query("SET time_zone = '+07:00'");

} catch (mysqli_sql_exception $e) {

    http_response_code(500);

    error_log($e->getMessage());

    exit('Database connection failed.');
}

function h(?string $value): string
{
    return htmlspecialchars(
        $value ?? '',
        ENT_QUOTES | ENT_SUBSTITUTE,
        'UTF-8'
    );
}

function text_length(string $value): int
{
    return function_exists('mb_strlen')
        ? mb_strlen($value, 'UTF-8')
        : strlen($value);
}
```

3.2 สร้างไฟล์ Lab09_add_book_insecure.php ไฟล์นี้ ใช้เพื่อสาธิตความเสี่ยงจากการนำ User Input โดยไม่มีการตรวจสอบข้อมูลนำเข้าในส่วนของ Server ให้ทดลองเฉพาะในระบบ Lab นี้เท่านั้น

```php
<?php
declare(strict_types=1);

require_once 'Lab09_config.php';

$title = $_POST['title'] ?? '';
$author = $_POST['author'] ?? '';
$isbn = $_POST['isbn'] ?? '';
$category = $_POST['category'] ?? '';
$publishYear = $_POST['publish_year'] ?? '';
$price = $_POST['price'] ?? '';
$stock = $_POST['stock'] ?? '';

$message = '';
$error = '';

$currentYear = (int) date('Y');

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    try {
        /*
        * Database Error Test
        * ใช้สำหรับจำลองข้อผิดพลาดของฐานข้อมูลใน Lab เท่านั้น
        */
        $table = isset($_GET['database_error_test'])
            ? 'books_error'
            : 'books';

        /*
         * ไม่มี Server-side Validation
         */
        $sql = "
            INSERT INTO {$table}
                (
                    title,
                    author,
                    isbn,
                    category,
                    publish_year,
                    price,
                    stock
                )
            VALUES (?, ?, ?, ?, ?, ?, ?)
        ";
```

```php
        $stmt = $conn->prepare($sql);

        $publishYearValue = (int) $publishYear;
        $priceValue = (float) $price;
        $stockValue = (int) $stock;

        $stmt->bind_param(
            'ssssidi',
            $title,
            $author,
            $isbn,
            $category,
            $publishYearValue,
            $priceValue,
            $stockValue
        );

        $stmt->execute();
        $stmt->close();

        $message = 'Book added.';

    } catch (mysqli_sql_exception $e) {

        /*
         * Insecure Error Handling:
         * แสดงรายละเอียด Database Error ต่อผู้ใช้โดยตรง
         */
        $error = $e->getMessage();
    }
}
?>

<!doctype html>
<html lang="th">
<head>
    <meta charset="utf-8">

    <meta
        name="viewport"
        content="width=device-width, initial-scale=1"
    >
    <title>Lab09 - Insecure Add Book</title>
    <style>
        body {
            font-family: Arial, sans-serif;
            background: #f3f6f9;
            margin: 0;
        }
        .container {
            width: min(760px, 94%);
            margin: 40px auto;
            background: #ffffff;
            padding: 28px;
            border-radius: 12px;
            box-shadow: 0 8px 30px rgba(0, 0, 0, .08);
        }
        label {
            font-weight: bold;
        }
```

```
        input,
        select {
            width: 100%;
            box-sizing: border-box;
            padding: 10px;
            margin-top: 6px;
        }
        button {
            padding: 10px 18px;
            border: 0;
            border-radius: 8px;
            cursor: pointer;
        }
        .warning {
            padding: 12px;
            background: #fff3cd;
            margin-bottom: 16px;
        }

        .success {
            padding: 12px;
            background: #d1e7dd;
            margin-bottom: 16px;
        }

        .error {
            padding: 12px;
            background: #f8d7da;
            margin-bottom: 16px;
            overflow-wrap: anywhere;
        }
    </style>
</head>

<body>
<div class="container">
    <h1>Insecure Add Book</h1>
    <div class="warning">
        Demonstration:
        Client-side Validation only
        + No Server-side Validation
        + Insecure Error Handling
    </div>
    <?php if ($message !== ''): ?>
        <div class="success">
            <?= h($message) ?>
        </div>
    <?php endif; ?>
    <?php if ($error !== ''): ?>
        <div class="error">
            <strong>Database Error:</strong><br>
            <?= h($error) ?>
        </div>
    <?php endif; ?>

    <form method="post">
        <label for="title">Title</label>
        <input
            type="text"
            id="title"
            name="title"
            required
            maxlength="150"
            value="<?= h($title) ?>" >
        <br><br>
```

```
171         <label for="author">Author</label>
172         <input
173             type="text"
174             id="author"
175             name="author"
176             required
177             maxlength="100"
178             value="<?= h($author) ?>" >
179         <br><br>
180         <label for="isbn">ISBN</label>
181         <input
182             type="text"
183             id="isbn"
184             name="isbn"
185             required
186             maxlength="20"
187             placeholder="9780132350884"
188             value="<?= h($isbn) ?>" >
189         <br><br>
190         <label for="category">Category</label>
191         <select
192             id="category"
193             name="category"
194             required >
195             <option value="">-- Select Category --</option>
196             <option value="Database">Database</option>
197             <option value="Programming">Programming</option>
198             <option value="Security">Security</option>
199         </select>
200         <br><br>
200         <br><br>
201         <label for="publish_year">Publish Year</label>
202         <input
203             type="number"
204             id="publish_year"
205             name="publish_year"
206             min="1900"
207             max="<?= h((string) $currentYear) ?>"
208             required
209             value="<?= h($publishYear) ?>" >
210         <br><br>
211         <label for="price">Price</label>
212         <input
213             type="number"
214             id="price"
215             name="price"
216             min="0.01"
217             max="999999.99"
218             step="0.01"
219             required
220             value="<?= h($price) ?>" >
221         <br><br>
222         <label for="stock">Stock</label>
223         <input
224             type="number"
225             id="stock"
226             name="stock"
227             min="0"
228             max="100000"
229             required
230             value="<?= h($stock) ?>">
231         <br><br>
232           <button type="submit">
233               Save
234           </button>
235       </form>
236   </div>
237   </body>
238   </html>
```

งานที่ 1.1 ทดสอบไฟล์ Lab09_add_book_insecure.php

1) เปิด http://localhost:8080/Lab09/Lab09_add_book_insecure.php

2) จากนั้นกรอกข้อมูลปกติสำหรับทดสอบ ดังนี้

Title: Network Security

Author: Alice Brown

ISBN: 9780132350884

Category: Security

Publish Year: 2025

Price: 480.50

Stock: 10

3) Capture หน้าจอผลลัพธ์ และข้อมูลในฐานข้อมูล

งานที่ 1.2 ทดสอบ Bypass Client-side Validation

1. เปิด Developer Tools (F12) ไปที่แท็บ Elements
2. ไปที่ Form ทดลองแก้เงื่อนไข HTML แล้วส่งค่าที่ผิดจากข้อกำหนด เช่น

– ช่อง Category เพิ่ม <option value="Hardware">Hardware</option>

– ช่อง Publish Year แก้เงื่อนไข HTML โดยลบ max="2026"

– ช่อง Price, Stock แก้เงื่อนไข HTML ลบ min="0" ออก



จากนั้นให้กรอกข้อมูลที่หน้าเว็บที่ผิดเงื่อนไข เช่น

Title: Database Design

Author: Mary Jones

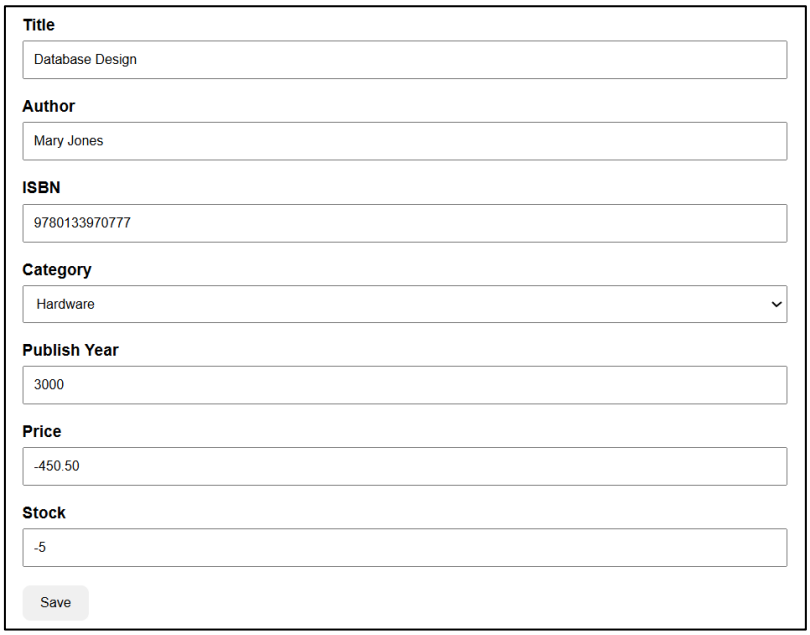
ISBN: 9780133970777

Category: Hardware

Publish Year: 3000

Price: -450.50

Stock: -5



3) Capture หน้าจอผลลัพธ์ และข้อมูลในฐานข้อมูล

งานที่ 1.3 ทดสอบ Insecure Error Handling

1) นำ ?database_error_test=1 ไปต่อท้าย URL เดิม ดังนี้

http://localhost:8080/Lab09/Lab09_add_book_insecure.php?database_error_test=1

ให้กรอกข้อมูล แล้ว กดปุ่ม Save

Title: PHP Programming

Author: Anna Lee

ISBN: 9781491905012

Category: Programming

Publish Year: 2025

Price: 390.00

Stock: 12

2) Capture หน้าจอผลลัพธ์

3.3 ให้สร้างไฟล์ Lab09_add_book_secure.php ด้วยตัวเอง โดยแก้ไขคำสั่งจากไฟล์ Lab09_add_book_insecure.php ให้มี Server-side Validation และ Secure Error Handling

งานที่ 2.1 ทดสอบไฟล์ Lab09_add_book_secure.php

1) เปิด http://localhost:8080/Lab09/Lab09_add_book_secure.php

ข้อมูลปกติสำหรับทดสอบ

Title: SQL Fundamentals

Author: John Smith

ISBN: 9780131873254

Category: Database

Publish Year: 2022

Price:100

Stock: 6

2) Capture หน้าจอผลลัพธ์ และข้อมูลในฐานข้อมูล

งานที่ 2.2 ทดสอบ Bypass Client-side Validation

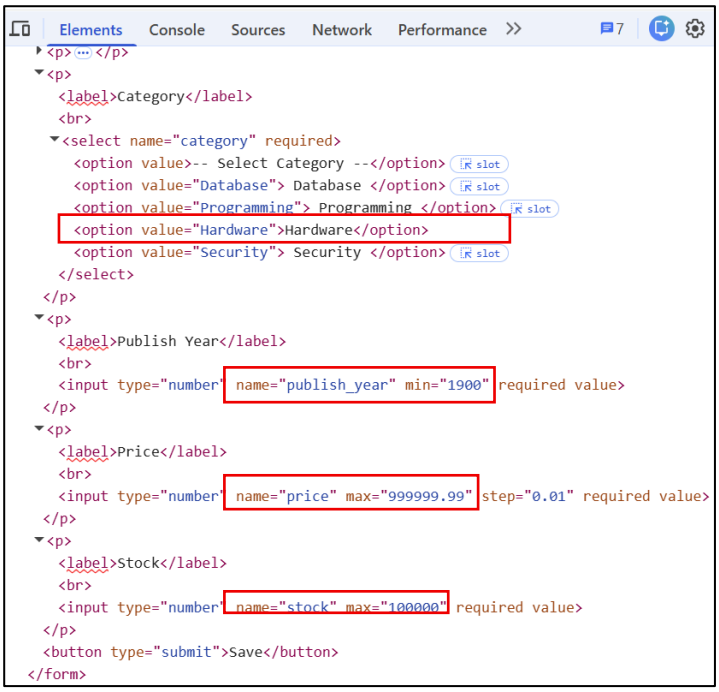
1) เปิด Developer Tools (F12) ไปที่แท็บ Elements ให้แก้ไขเหมือนงานที่ 1.2

2) ไปที่ Form ทดลองแก้เงื่อนไข HTML แล้วส่งค่าที่ผิดจากข้อกำหนด เช่น

ช่อง Category เพิ่ม <option value="Hardware">Hardware</option>

ช่อง Publish Year แก้เงื่อนไข HTML โดยลบ max="2026"

ช่อง Price, Stock แก้เงื่อนไข HTML ลบ min="0" ออก



3) จากนั้นให้กรอกข้อมูลที่หน้าเว็บที่ผิดเงื่อนไข เช่น

Title: Secure Coding

Author: Peter Brown

ISBN: 9780135957059

Category: Hardware

Publish Year: 3001

Price: -400.50

Stock: -7

4) Capture หน้าจอผลลัพธ์ และข้อมูลในฐานข้อมูล

งานที่ 2.3 ทดสอบ Secure Error Handling

1) นำ ?database_error_test=1 ไปต่อท้าย URL เดิม ดังนี้

http://localhost:8080/Lab09/Lab09_add_book_secure.php?database_error_test=1

ให้กรอกข้อมูล แล้ว กดปุ่ม Save

Title: Secure Coding

Author: Peter Brown

ISBN: 9780135957059

Category: Security

Publish Year: 2024

Price: 300.00

Stock: 11

2) Capture หน้าจอผลลัพธ์ และข้อมูลในฐานข้อมูล

3) เปิด Command Prompt แล้วพิมพ์คำสั่ง docker logs php_apache --tail 30

4) Capture ผลลัพธ์ที่ได้จากคำสั่ง